

Phase 24 — MCP Gateway — CLOSEOUT + FREEZE (the non-bypass drill)

Frozen: 2026-06-17. **Scope frozen:** the whole MCP gateway — `src/lib/mcp-gateway/` (read server + proposal path + identity + scope + DoS) plus its executor-side leaves (`src/lib/canonical-policy/` , `src/lib/chat/approval-revalidation.ts` , `src/lib/chat/bulk-reject.ts`). A local **stdio** MCP server: external clients may READ two governed surfaces and PROPOSE into the approval queue; they may **never cross the Human Gate**. **Builds on:** 24B read-server `d6e763b` , 24C FC-1/FC-2 `760e5ed` / `1556e7a` / `ac78099` , 24C-3 injection drills `2551f8b` , 24D-1 identity `6e81815` , 24D-2a scope `ebd5be7` , 24D-2b E-016 close `68485f0` , 24D-3 DoS `a033309` . All present in HEAD. **Drill test:** `tests/mcp-gateway/phase-24e-nonbypass-drill.test.ts` (DRILL-1..12). **Threat model:** `docs/security/MCP_GATEWAY_THREAT_MODEL.md` (v3 — taxonomy resolved AMBER→GREEN by drill). **Read-server freeze:** `PHASE24B_CLOSEOUT.md` .

This is a **verification-and-freeze** slice. It adds the drill test, this document, the threat-model resolution, the E-018 timeout bump, and a registry banner. **It changes no gateway behavior and adds no capability.**

0. The core proof — `runtime.runTool` is still EXACTLY 2

The whole gateway — read server, FC-1/FC-2 proposal path, FC-3 identity, per-client scope, the DoS family, human bulk-reject — added **ZERO** mutation paths. The single mutation path is unchanged from the Phase 23 baseline.

- **Two production call sites, both in the frozen chat/ tree:** `src/lib/chat/tool-approvals.ts:390` (the governed `resumeApproval` executor) and `src/lib/chat/tool-continuation.ts:238` (read-only provider continuation).
- **The gateway directory contains none.** `src/lib/mcp-gateway/**` has no `runtime.runTool` call site; nor do the executor-side leaves (`canonical-policy/` , `approval-revalidation.ts` , `bulk-reject.ts` — the last reuses the EXISTING `denyApproval` + `updateToolCall` , never `runTool`).
- **Machine-check:** `phase-24e-nonbypass-drill.test.ts` **DRILL-12** walks all of `src/lib` (non-test) and asserts exactly 2 `.runTool(` sites, both under `src/lib/chat/` , plus zero in the gateway dir. (Also held by `phase-24b-closeout.test.ts` l-24B3-5 and `tool-approvals-revalidation.test.ts` l-24C2b-5.)

1. The five Phase-23 architecture invariants — re-verified with the gateway built

Each: the claim, the gateway impact, the evidence (file:line), the machine-check. (Originals: `docs/audits/PHASE23_CLOSEOUT_VERIFICATION.md` .)

I1 — Single mutation path (no execution call site outside the approved-proposal handler) — PASS

- **Gateway impact:** none. The gateway is a *producer*: it canonicalizes, freezes, and enqueues a `pending` proposal, then stops. It has no path to the executor (GATE-2). `resumeApproval` (`tool-approvals.ts:244`)

remains the sole executor; its lone `runtime.runTool ( :390 )` is gated by the 24C-2b/24D-2b re-validation guard inserted *before* it.

- **Evidence:** the two call sites above; the gateway adds none.
- **Machine-check:** DRILL-12; DRILL-2 (a valid proposal enqueues `pending`, never executes).

I2 — No raw frames / OCR / transcripts / payloads in any sink or surface — PASS

- **Gateway impact:** the gateway's two reads and its proposal projection are **metadata-only**, enforced by the zero-import leaf sanitizer.
 - Reads: `readPipelineViewModel` wraps the build in `sanitizeReadPayload ( resources.ts:68 )`; the queue-status branch is a counts-only projection (`queue-status.ts`, `typed source () => number`).
 - Proposal effect: the FC-1 canonical effect must pass `findForbiddenFields` at derivation (`canonicalize.ts:211`) and again at the enqueue needle's eye (`enqueue.ts:91`); the target is structurally masked, no arg values copied.
 - Injection projection: client free-text is fenced into `untrusted_client_text ( presentation.ts:129 )`, never merged into the trusted channel.
- **Machine-check:** DRILL-1 (never-exposed surfaces denied); DRILL-3 (payload stays untrusted; trusted channel carries only the server effect); the sanitizer suites (`server.test.ts`, `queue-status.test.ts`).

I3 — Vision provider execution gated by default — PASS (gateway introduced no violation)

- **Gateway impact:** none. The gateway exposes no vision/capture surface and **cannot reach** `vision-runtime/` or `video-extraction/` — those trees are outside the GATE-2 allowlist (`ALLOW_PREFIXES` = the gateway + the read projection + the canonical-policy leaf only). The Phase-23 gating (`vision-runtime/policy.ts:155-156`, default-deny) is untouched.
- **Machine-check:** DRILL-9 (no gateway file imports a denied tree); `transitive-import-allowlist.test.ts` (transitive, build-failing).

I4 — No background or autonomous capture path — PASS (gateway introduced no violation)

- **Gateway impact:** none. The gateway is **request-driven** over `stdio` (`server.ts` reads newline-delimited JSON-RPC; nothing runs at import time); it has no `setInterval` /scheduler/cron and initiates nothing. It adds no capture path and cannot reach the capture trees (GATE-2). The Phase-23 no-autonomous-capture controls are untouched.
- **Machine-check:** DRILL-9; DRILL-12 (no executor reachable to act autonomously).

I5 — Pipeline/audit surfaces carry no execute/approve/mutate affordances — PASS

- **Gateway impact:** none added. The exposed `pipeline-view-model` carries `execute_affordance_present:false`, `approve_affordance_present:false`, `mutation_affordance_present:false` (`contracts.ts:222-224` type, `:771-773` value) and an empty `controls:[]`. The gateway adds **no** method that proposes-as-approved, approves, executes, or mutates — its JSON-RPC surface is `initialize` / `resources/list` / `resources/read` only; the proposal path produces a `pending` row and stops.

- **Machine-check:** DRILL-2 (proposal awaits human); DRILL-11 (no method beyond the read surface; `tools/call` → uniform denial).

2. The non-bypass drill — every elevation path fails closed

`phase-24e-nonbypass-drill.test.ts` drives a real external client over the **actual stdio entry** (`startStdioServer`) where feasible; the propose / revalidate / admission paths (no JSON-RPC propose method exists — the gateway is read-only on the wire, the submit pipeline is a library boundary) are driven via their **real code path** directly, noted per drill.

Drill	Attack	Result (fail-closed)	Control
DRILL-1	read a never-exposed surface (telemetry/memory)	uniform denial; nothing returned (stdio)	ID-0/ID-5
DRILL-2	submit a valid proposal	enqueues <code>pending</code> , does not execute	EoP-2 (frozen P18)
DRILL-3	"AUTO-APPROVED" injection text	fenced in <code>untrusted_client_text</code> ; trusted channel = server effect; voice speaks trusted	EoP-3/11/15
DRILL-4	proposal with no stampable <code>client_id</code>	rejected <code>no_provenance</code> , not queued	EoP-5
DRILL-5	no token / off-allowlist / disabled client	refused; unauthenticated; every read denied (stdio)	FC-3 / Spoofing
DRILL-6	out-of-scope read + out-of-grant/target propose	denied (ID-2); rejected <code>no_grant</code> / <code>target_out_of_scope</code>	ID-2/EoP-13/EoP-4
DRILL-7	client-authored effect/risk/target + forged hash	<code>malformed_request</code> (GATE-3); <code>hash_mismatch</code> at the needle's eye (GATE-5)	FC-1/EoP-7/GATE-5
DRILL-8a	hash-frozen approval whose stored effect drifts	DENIED at the decision guard, no execution	FC-2 (TOCTOU)
DRILL-8b	capability declassified after queueing	DENIED <code>tool_declassified</code> at the decision point	E-016 / 24D-2b
DRILL-8c	write an approval-decision event from the gateway	impossible — no executor/writer call in any gateway file	EoP-12 (allowlist)
DRILL-9	import a mutator tree (direct/transitive)	no gateway file reaches a denied tree; the standing test fails the build; policy bites	EoP-6 / GATE-2
DRILL-10	flood: rate / quota / depth / mute / read-hammer	rejected before freeze; reads denied over rate; one flood never blocks another	EoP-9/10 / ID-3
DRILL-11	probe denials to map surfaces/scopes	unknown / forbidden / unwired / bad-method all INDISTINGUISHABLE	ID-5
DRILL-12	(the core proof) any new mutation path	<code>runtime.runTool</code> count EXACTLY 2; zero in the gateway	EoP-1/EoP-6

All 12 pass (26 `it` assertions). Each is its own small `it` — no whole-repo scan inside one `it` (E-013/E-015 lesson).

3. Threat-model resolution + the one named residual

`MCP_GATEWAY_THREAT_MODEL.md` is updated from the honest AMBER-PLANNED taxonomy to **GREEN by drill** for every control now built and exercised: FC-1, FC-2 (both halves), FC-3; EoP-3/4/5/6/7/8/9/10/12/13/15; ID-0/1/2/3/4/5; Spoofing / Tampering / Repudiation / DoS / stdio-local-≠-trusted. EoP-11 is GREEN for the **voice + data-layer** channel separation (24C-3 + DRILL-3); the **visual UI rendering** stays a cross-phase requirement encoded in the data (`render_hardening`) for the future UI capstone — recorded, not overclaimed.

The one open per-client residual — E-017 (TRACKED-OPEN → 24D-4): per-client GRANT revocation is not re-checked at the *decision point*, because the frozen canonical effect is client-agnostic (no `client_id` on the approval row, by FC-1 design). Submission-time per-client abuse is contained (24D-3 rate / quota / depth / mute at queue time). This is a bounded, named residual, not a RED threat; it does not block the freeze.

Honest final posture: gateway **SECURITY SIGN-OFF GIVEN** for what is drilled (DRILL-1..12). The one remaining per-client decision-time re-validation (E-017) is sequenced to 24D-4.

4. The E-018 timeout bump (load-tolerant gate)

24D-3 characterized a chronic, load-induced flake: whole-repo-scan governance/ closeout audits and `sqlite :memory:` `beforeEach` hooks time out at vitest's stock 5s/10s defaults **only under machine load** (the pre-commit hook runs `eslint` then `vitest` back-to-back), never on assertion. E-018 raises the **global** ceilings in `vitest.config.ts` — `testTimeout: 120_000`, `hookTimeout: 30_000` — AND runs the suite single-worker in-hook (`maxWorkers: 1` , the Vitest-4 top-level option). The ceilings alone were NOT enough: the pre-commit machine was MEMORY-STARVED (~0.7 GB free of 16 GB, 8 cores) — at the stock fork count a worker OOM-crashed ("Worker exited unexpectedly"); even half the cores left the heavy whole-repo-scan audits + the big-PDF tool parse paging to swap until they blew their per-test budgets. Minimum-footprint single-worker gives each test the full RAM/disk so it finishes in ~its standalone time; the gate is reliable under memory pressure (slower wall-clock, fine for a background pre-commit run). A genuinely hung test still fails (just later).

Assertions are unchanged (test budgets + concurrency only). Acceptance: the full suite passes **inside the pre-commit hook** with no load-induced timeout or crash.

5. Freeze declaration

Phase 24 (the MCP gateway) is **FROZEN as of 2026-06-17**. Frozen surface: the exposure set (**exactly two reads**), FC-1 (server-derived effect), FC-2 (hash-freeze + decision-time re-validation), FC-3 (identity), per-client scope + EoP-13 completeness, and the DoS family. Any further change — a third exposed read, a new proposable capability, a new mutation path, any behavior change — requires an **exposure-matrix amendment + a new registry entry above the banner first** (`docs/enhancements/REGISTRY.md`) and a new slice. E-017 (per-client decision-time grant re-validation) and E-018 (the timeout bump) are noted.